URBANMINIMAL

LỘ TRÌNH TRIỂN KHAI DỰ ÁN 8 TUẦN

Website thương mại điện tử thời trang · Node.js · Express · EJS (SSR) · MongoDB Atlas

Nhóm 4 thành viên · Cân bằng tải 25% / người · 4 Phase × 2 tuần

Thông tin	Nội dung
Phong cách	Đen tối giản (Minimalist Black), ưu tiên Mobile
Đối tượng	Học sinh, sinh viên 18–25 tuổi
Mục tiêu hiệu năng	Lighthouse Mobile > 90 (chỉ tiêu, cần đo thực tế)
Luồng thanh toán	1-Page Checkout
Ràng buộc	Không dùng AI trong sản phẩm; Express thuần + EJS; không dùng framework Frontend
Nguồn	Prompt yêu cầu của nhóm + Báo cáo hướng làm và phân tích hệ thống (ngày 04/11/2026)

1. Tổng quan và nguyên tắc chung

1.1. Phân vai (mỗi người 25% khối lượng)

Vai trò	Trách nhiệm chính	Bằng chứng đóng góp
Dev 1 Leader & Lead Backend Core	Cấu trúc MVC, validate Env/Request (Zod), JWT Auth, RBAC, Error Handler, API User/Profile, bảo mật, deploy ứng dụng	Commit ở `config/` `middlewares/` `controllers/auth*`, báo cáo mục Bảo mật
Dev 2 Backend Business & Database	Mongoose Schema, API Category/Product/Cart/Order/Checkout, Soft-delete, trừ kho nguyên tử, deploy DB	Commit ở `models/` `services/`, báo cáo mục CSDL + Nghiệp vụ
Dev 3 Lead Frontend Architect & Logic	Layout EJS Mobile-First, CSS/Tailwind Minimalist Black, JS Client (DOM, giỏ hàng, Fetch API), tối ưu Lighthouse	Commit ở `public/` `views/layouts` `views/partials`, báo cáo mục Giao diện + Hiệu năng
Dev 4 Frontend Views & QA	View EJS (Home, Catalog, Detail, Cart, Checkout, Admin), Jest/Supertest, báo cáo/slide	Commit ở `views/pages` `views/admin` `tests/` `docs/`, báo cáo mục Kiểm thử

1.2. Quy ước làm việc

- **Git:** nhánh `main` (ổn định) ← `develop` ← `feature/<tên>-<việc>`. Mọi PR cần 1 người khác duyệt.
- **Họp:** 15 phút đầu tuần (chia việc) + 15 phút cuối tuần (demo tích hợp + chạy tiêu chí Verify).
- **Hợp đồng API:** Dev 2 và Dev 1 chốt endpoint (mục 4) vào thứ Hai của tuần để Dev 3, Dev 4 làm song song, không chờ.
- **Definition of Done:** chạy được local · có test hoặc kịch bản kiểm tay · PR đã duyệt · không có lỗi console · cập nhật tài liệu.
- **Nguồn sự thật:** máy chủ luôn tính lại giá và tồn kho; JS phía trình duyệt chỉ để tăng trải nghiệm.

1.3. Tổng quan 4 Phase

Phase	Tuần	Mục tiêu	Kết quả chính (demo cuối phase)
1	1–2	Khảo sát, thiết kế DB, setup nền tảng	App chạy, env được validate, schema + seed, layout mobile
2	3–4	CRUD, Auth, Catalog	Đăng nhập/đăng ký, RBAC, lọc sản phẩm đúng, trang Catalog/Detail
3	5–6	Giỏ hàng, đơn hàng, 1-Page Checkout	Luồng Guest → đăng nhập → đặt hàng → Admin xác nhận; trừ kho an toàn
4	7–8	Test, tối ưu, deploy, báo cáo	Bản chạy online, test đạt, Lighthouse đo thực tế, báo cáo A–Z

2. Điểm cần chốt sớm (không tự giả định)

#	Vấn đề	Mâu thuẫn / rủi ro	Đề xuất trong lộ trình
1	Giỏ hàng	Prompt ghi "LocalState"; báo cáo ghi giỏ Guest lưu session server, gộp vào DB khi đăng nhập	Dùng cách của báo cáo; Dev 3 giữ bản sao UI tạm. **Cần nhóm xác nhận.**
2	Thời điểm trừ kho	Trừ khi đặt thì phải hoàn kho khi khách bỏ thanh toán online	Trừ khi đặt + job hết hạn đơn chưa thanh toán. **Hỏi giảng viên.**
3	Dữ liệu Tỉnh/Quận/Phường	Báo cáo cảnh báo có thể lỗi thời sau đợt sắp xếp hành chính 2025; chưa tra nguồn	Dev 3 chọn nguồn dữ liệu ở Tuần 1; xác nhận với giảng viên. **Tôi không biết dữ liệu mới nhất.**
4	Thư viện CSRF	Báo cáo ghi `csurf` có thể đã ngừng duy trì; chưa tra cứu	Dev 1 tra tài liệu chính thức ở Tuần 2 rồi chọn giải pháp còn được hỗ trợ
5	Làm sạch đầu vào	DOMPurify cần môi trường DOM trên Node.js	Dev 1 cân nhắc `xss`/`sanitize-html`; bắt buộc thoát ký tự đầu ra EJS (`<%= %>`)
6	Gói miễn phí Render/Atlas	Giới hạn và chính sách thay đổi thường xuyên; chưa kiểm chứng	Dev 1, Dev 2 đọc tài liệu chính thức trước Tuần 8

#	Vấn đề	Mâu thuẫn / rủi ro	Đề xuất trong lộ trình
7	Zod, Tailwind, Lighthouse > 90	Có trong prompt nhưng báo cáo không đề cập	Giữ theo prompt. Lighthouse > 90 là chỉ tiêu, chưa biết có đạt hay không
8	Trạng thái đơn	Báo cáo bổ sung "Đã xác nhận" so với khung gốc 4 trạng thái	Dùng 5 trạng thái; nếu giảng viên yêu cầu 4 thì gộp

3. Lộ trình chi tiết từng tuần

Mỗi tuần mỗi người có đúng **3 đầu việc** (tổng 96 đầu việc, 24/người) để đảm bảo công bằng khi chấm đóng góp.

PHASE 1 – Khảo sát, thiết kế DB, nền tảng

Tuần 1 – Khảo sát và khởi tạo dự án

Vai trò	Công việc (3 đầu việc)
Dev 1 Lead Backend	• Khởi tạo repo, `npm init`; dựng cấu trúc MVC `src/{config,routes,controllers,services,models,middlewares,utils,views,public}`; ESLint + Prettier. • `config/env.js`: validate biến môi trường bằng **Zod** (MONGO_URI, JWT_SECRET, SESSION_SECRET, PORT, NODE_ENV); thiếu thì dừng app. • Tạo `.env.example`, `.gitignore`, README cài đặt; thiết lập nhánh Git và quy tắc PR.
Dev 2 Backend Business	• Phân tích nghiệp vụ, vẽ ERD: User, Category, Product (nhúng `variants`), Order (nhúng `items`), Cart, Review. • Chốt quy tắc nhúng/tham chiếu, mã SKU biến thể, trường Soft-delete (`isDeleted`, `deletedAt`). • Tạo cụm MongoDB Atlas cho dev; viết `config/db.js` (Mongoose) có xử lý lỗi kết nối.
Dev 3 Lead Frontend	• Vẽ wireframe mobile: Home, Catalog, Detail, Cart, Checkout, Admin (Minimalist Black). • Cài Tailwind, cấu hình build ra `public/css/app.css`; khai báo design tokens (màu, font, khoảng cách). • Dựng `views/layouts/main.ejs` Mobile-First (viewport, meta, vùng nội dung) bằng express-ejs-layouts.
Dev 4 Views & QA	• Khảo sát hệ thống: tác nhân, ma trận RBAC (Guest/Customer/Admin), use case 4 phân hệ. • Lập danh sách yêu cầu phi chức năng (hiệu năng, bảo mật IDOR/XSS/CSRF) và kế hoạch kiểm thử sơ bộ. • Vẽ sơ đồ use case + máy trạng thái đơn hàng; dựng khung tài liệu `docs/` và mục lục báo cáo.

Verify chung: Server khởi động; thiếu biến môi trường thì báo lỗi rõ; kết nối Atlas thành công; layout hiển thị đúng ở 360px và 768px; ERD đã được cả nhóm duyệt.

Tuần 2 – Nền tảng bảo mật, Schema, Base UI

Vai trò	Công việc (3 đầu việc)
Dev 1 Lead Backend	• `app.js`: Helmet, giới hạn body, cookie-parser, session (kho bền trên MongoDB), compression, static cache. • Error Handler tập trung: lớp `AppError`, trang `error.ejs` cho giao diện, JSON lỗi cho `/api`; xử lý 404. • Middleware `validate(schema)` dùng Zod cho request; tra cứu và chọn thư viện CSRF còn được hỗ trợ.
Dev 2 Backend Business	• Viết Mongoose Schema: User, Category, Product (variants + SKU), kèm ràng buộc và message lỗi. • Viết Schema Order (items + price snapshot), Cart, Review. • Khai báo index: unique email/slug, `(category, price)`, multikey `variants.size/color`; script seed 6 sản phẩm + admin.
Dev 3 Lead Frontend	• Partial `navbar`, `footer`, `flash`, `product-card`. • Thư viện component CSS: button, input, badge, card, grid 2 cột mobile. • Trang thử layout; kiểm tra hiển thị ở 360/390/768/1280px; chốt nguồn dữ liệu Tỉnh/Quận/Phường.
Dev 4 Views & QA	• Cài Jest + Supertest; `tests/setup.js` dùng CSDL test riêng. • Viết test smoke cho `/health` và test validate env. • Hoàn thiện sơ đồ ERD + use case vào báo cáo; lập checklist code review chung.

Verify chung: `npm start` chạy được; seed thành công; mọi lỗi trả đúng định dạng (trang EJS hoặc JSON); test smoke xanh; Dev 3 dùng được model seed để hiển thị thẻ sản phẩm.

PHASE 2 – CRUD, Auth, Catalog

Tuần 3 – Xác thực và CRUD cơ bản

Vai trò	Công việc (3 đầu việc)
Dev 1 Lead Backend	• Đăng ký: kiểm tra Zod, trùng Email → 409, băm bcrypt, vai trò mặc định Customer (không nhận role từ client). • Đăng nhập: thông báo chung "Email hoặc mật khẩu không đúng"; cấp JWT ngắn hạn trong cookie HttpOnly + Secure + SameSite. • Đăng xuất và cơ chế refresh token; cấu hình thời hạn token qua env.
Dev 2 Backend Business	• API Category: CRUD, slug duy nhất, cây cha/con, Soft-delete. • API Product: CRUD, validate Zod, chặn trùng cặp Size–Màu, tồn kho >= 0, lưu URL ảnh (không lưu nhị phân). • Query helper loại bản ghi `isDeleted` mặc định; test thủ công bằng Postman.
Dev 3 Lead Frontend	• JS trang chi tiết: nhận JSON biến thể do server nhúng, chọn Màu thì làm mờ Size hết hàng. • Module `public/js/api.js`: bọc fetch, gắn CSRF header, xử lý lỗi thống nhất. • Toast/flash JS; xử lý trạng thái loading của nút (chống bấm đúp).
Dev 4 Views & QA	• View Đăng nhập/Đăng ký: form, hiển thị lỗi, flash message. • View Home: hero, danh mục nổi bật, sản phẩm mới (dùng partial của Dev 3). • Test Auth: trùng email 409, sai mật khẩu, cookie có cờ HttpOnly.

Verify chung: Đăng ký → đăng nhập → thấy tên trên navbar; cookie không đọc được bằng JS; CRUD Category/Product chạy qua Postman; Home hiển thị dữ liệu seed.

Tuần 4 – RBAC, bộ lọc, Catalog

Vai trò	Công việc (3 đầu việc)
Dev 1 Lead Backend	• Middleware `authenticate` và `authorize(...roles)`; helper kiểm tra quyền sở hữu (chống IDOR). • Giới hạn tần suất cho đăng nhập/quên mật khẩu; bật CSRF cho mọi form POST. • API User/Profile: xem, cập nhật hồ sơ, đổi mật khẩu (không trả trường mật khẩu).
Dev 2 Backend Business	• `buildFilter()`: danh mục, khoảng giá, từ khóa (thoát ký tự regex), Size+Màu+tồn kho > 0 bằng `$elemMatch`. • Phân trang + sắp xếp (mới nhất, giá tăng/giảm); ép giới hạn tối đa số bản ghi mỗi trang. • Tối ưu truy vấn: `.lean()`, chỉ lấy trường cần cho danh sách; kiểm tra index bằng `explain()`.
Dev 3 Lead Frontend	• JS bộ lọc: thanh trượt giá, giữ trạng thái form GET, ngăn gửi giá trị không hợp lệ. • Phân trang bằng liên kết giữ nguyên tham số lọc; hiển thị số kết quả. • Lazy loading ảnh, skeleton, CSS lưới Catalog 2 cột mobile; drawer bộ lọc trên mobile.
Dev 4 Views & QA	• View Catalog (sidebar/drawer lọc, thanh phân trang) và Product Detail (gallery, chọn Size/Màu, nút thêm giỏ). • View Profile (xem/sửa hồ sơ, đổi mật khẩu). • Test RBAC: Customer xóa sản phẩm → 403, chưa đăng nhập → 401; test bộ lọc "M + Đỏ" không ra sản phẩm chỉ có M-Xanh và S-Đỏ.

Verify chung: Lọc "M + Đỏ" chính xác; Customer không vào được route Admin (403); trang Catalog lọc, sắp xếp, phân trang chạy ổn trên mobile; form POST thiếu CSRF bị từ chối.

PHASE 3 – Nghiệp vụ thương mại

Tuần 5 – Giỏ hàng và vòng đời đơn

Vai trò	Công việc (3 đầu việc)
Dev 1 Lead Backend	• Gộp giỏ Guest (session) vào giỏ Customer (DB) ngay khi đăng nhập. • Service máy trạng thái đơn: Chờ xác nhận → Đã xác nhận → Đang giao → Đã giao; Hủy chỉ ở hai trạng thái đầu; chặn chuyển lùi. • API Admin: danh sách người dùng, đổi vai trò (có kiểm tra không tự hạ quyền chính mình).
Dev 2 Backend Business	• API Cart: thêm, sửa số lượng, xóa; tính lại giá từ DB, không tin giá client. • Kiểm tra số lượng so với tồn kho đúng biến thể (SKU); trả lỗi 409 rõ ràng. • Hai chế độ giỏ: Guest (session) và Customer (document Cart riêng tham chiếu User).
Dev 3 Lead Frontend	• JS giỏ hàng: đổi số lượng, xóa dòng, cập nhật tổng tiền và badge trên navbar. • Đồng bộ với server bằng Fetch; server là nguồn sự thật, UI chỉ giữ bản sao tạm. • Hiển thị lỗi hết hàng theo từng dòng, giữ nguyên trạng thái khi lỗi mạng.
Dev 4 Views & QA	• View Cart (danh sách dòng, tổng, nút thanh toán). • Khung view Checkout (form giao nhận, tóm tắt đơn, phương thức thanh toán). • Test Cart: giá lấy từ DB, vượt tồn kho bị chặn, gộp giỏ khi đăng nhập.

Verify chung: Thêm sản phẩm khi là Guest → đăng nhập → giỏ vẫn còn; vượt tồn kho báo lỗi đúng biến thể; chuyển trạng thái sai thứ tự bị từ chối.

Tuần 6 – Checkout, kho an toàn, Admin

Vai trò	Công việc (3 đầu việc)
Dev 1 Lead Backend	• API Admin đổi trạng thái đơn theo máy trạng thái; Customer hủy đơn của chính mình (kiểm tra sở hữu + trạng thái). • Audit log cho thao tác Admin (đổi trạng thái đơn, đổi vai trò). • Tác vụ định kỳ hủy đơn chưa thanh toán quá hạn (nếu nhóm chốt trừ kho khi đặt).
Dev 2 Backend Business	• Checkout service: trừ kho **nguyên tử** có điều kiện trên đúng biến thể (xem mục 5); lỗi thì hoàn lại hoặc dùng transaction đa tài liệu. • Tạo Order: chụp giá, tên, ảnh từng dòng; xóa dòng đã mua khỏi giỏ; hủy đơn thì cộng trả kho. • Aggregation cho Dashboard: doanh thu theo thời gian, danh mục bán chạy, biến thể chạm ngưỡng tồn kho.
Dev 3 Lead Frontend	• JS 1-Page Checkout: chọn Tỉnh/Quận/Phường phụ thuộc bậc qua `/api`; validate phía client. • Chống bấm đúp khi đặt hàng; thanh tóm tắt đơn cố định ở đáy mobile. • Tích hợp Chart.js cho Dashboard (nhận JSON server nhúng); JS dòng biến thể động ở form sản phẩm Admin.
Dev 4 Views & QA	• View Đơn của tôi (danh sách + chi tiết + nút Hủy chỉ hiện khi hợp lệ). • View Admin: Dashboard, quản lý sản phẩm (form biến thể), danh mục, đơn hàng (tab trạng thái), người dùng. • Test Checkout/Order: giá snapshot, hủy đơn hoàn kho, IDOR đơn của người khác.

Verify chung: Chạy trọn luồng: lọc → thêm giỏ → checkout 1 trang → đơn tạo ở trạng thái Chờ xác nhận → Admin xác nhận → khách thấy trạng thái đổi; tồn kho giảm đúng; hủy đơn hoàn kho.

PHASE 4 – Kiểm thử, tối ưu, triển khai, báo cáo

Tuần 7 – Kiểm thử và tối ưu

Vai trò	Công việc (3 đầu việc)
Dev 1 Lead Backend	• Rà soát bảo mật: CSP bằng nonce (Helmet), cookie Secure + `trust proxy`, không lộ trường mật khẩu/stack trace. • Chốt và áp dụng sanitize đầu vào (thư viện cho Node) + kiểm tra mọi chỗ in dữ liệu dùng cú pháp thoát ký tự của EJS. • Rà soát rate limit, kích thước body, cờ cookie; viết checklist bảo mật cho báo cáo.
Dev 2 Backend Business	• Kiểm thử đồng thời tồn kho: biến thể còn 1, gửi nhiều request cùng lúc; chụp kết quả. • Tối ưu truy vấn: kiểm tra `explain()`, projection, index; xử lý N+1. • Lưu đệm khối ít đổi (cây danh mục/Mega Menu) và đo thời gian phản hồi.
Dev 3 Lead Frontend	• Lighthouse Mobile: minify CSS/JS, loại JS thừa, nén gzip/brotli. • Ảnh: kích thước phù hợp, định dạng nhẹ, `loading="lazy"`, preload font chính. • Cache-Control cho tài nguyên tĩnh; đo trước/sau và lưu ảnh chụp báo cáo.
Dev 4 Views & QA	• Test E2E: tạo khách → lọc/mua → Admin xác nhận → kiểm tra tồn kho và trạng thái. • Test bảo mật: IDOR, XSS (form địa chỉ/đánh giá), CSRF, RBAC. • Báo cáo độ phủ (coverage); ghi kết quả test có ảnh chụp vào tài liệu.

Verify chung: Toàn bộ test xanh; đúng 1 đơn thành công khi tồn kho = 1, tồn cuối bằng 0 (không âm); các kịch bản IDOR/XSS/CSRF bị chặn; có số liệu Lighthouse trước/sau.

Tuần 8 – Triển khai và đóng gói

Vai trò	Công việc (3 đầu việc)
Dev 1 Lead Backend	• Deploy ứng dụng lên Render/Railway: biến môi trường Production, health check, tự khởi động lại. • Kiểm tra cookie Secure và CSRF hoạt động đúng sau proxy thật. • Tạo tài liệu vận hành: cách deploy, biến môi trường, xử lý sự cố thường gặp.
Dev 2 Backend Business	• Cấu hình MongoDB Atlas production: tài khoản quyền tối thiểu, IP Access List, sao lưu. • Seed dữ liệu production và kiểm tra transaction/trừ kho trên môi trường thật. • Viết phần CSDL + Nghiệp vụ trong báo cáo (ERD cuối, index, lập luận kho nguyên tử).
Dev 3 Lead Frontend	• Sửa lỗi UI cuối; kiểm tra trên thiết bị thật và nhiều trình duyệt. • Đo Lighthouse Mobile lần cuối trên bản deploy; ghi số liệu thực tế. • Viết style guide giao diện và phần Giao diện + Hiệu năng trong báo cáo.
Dev 4 Views & QA	• Hoàn thiện báo cáo dự án A–Z (đánh số hình/bảng theo quy định khoa). • Làm slide và kịch bản demo; tập dượt toàn nhóm. • Lập bảng đóng góp cuối cùng (commit, PR, test) cho từng thành viên.

Verify chung: Bản online chạy được toàn bộ luồng; báo cáo + slide hoàn chỉnh; bảng đóng góp khớp lịch sử Git; demo chạy trơn tru.

4. Hợp đồng API đề xuất (để làm song song)

Đây là đề xuất để nhóm thống nhất từ Tuần 2; endpoint cuối cùng do Dev 1 và Dev 2 chốt.

Nhóm	Phương thức & đường dẫn	Quyền	Phụ trách
Auth	POST /auth/register · POST /auth/login · POST /auth/logout · POST /auth/refresh	Guest	Dev 1
Profile	GET/PUT /profile · PUT /profile/password	Customer*	Dev 1
Category	GET /categories · POST/PUT/DELETE /admin/categories	Guest / Admin	Dev 2
Product	GET /products (lọc, phân trang) · GET /products/:slug · POST/PUT/DELETE /admin/products	Guest / Admin	Dev 2
Cart	GET /cart · POST /cart/items · PUT /cart/items/:sku · DELETE /cart/items/:sku	Guest, Customer	Dev 2
Order	POST /checkout · GET /orders · GET /orders/:id · POST /orders/:id/cancel	Customer*	Dev 2
Admin đơn	GET /admin/orders · PUT /admin/orders/:id/status	Admin	Dev 1 + Dev 2
Admin người dùng	GET /admin/users · PUT /admin/users/:id/role	Admin	Dev 1
Địa chỉ	GET /api/locations/provinces · /districts · /wards (nguồn dữ liệu chờ xác nhận)	Guest	Dev 3

** = chỉ trên dữ liệu của chính mình (cần kiểm tra quyền sở hữu).*

5. Minh họa trừ kho nguyên tử (Dev 2)

Mục đích: tránh bán vượt kho khi hai khách cùng mua biến thể còn 1 sản phẩm. Kiểm tra và trừ kho nằm trong **một** lệnh cập nhật có điều kiện. Đoạn mã dưới là minh họa cho nhóm, cần chỉnh theo schema thực tế.

```
// Trừ kho một dòng hàng, trả về true nếu thành công
async function reserveStock(productId, sku, qty, session) {
  // updateOne: kiểm tra điều kiện và trừ kho trong cùng một thao tác
  const result = await Product.updateOne(
    {
      _id: productId,                          // đúng sản phẩm
      variants: { $elemMatch: {                // điều kiện áp lên CÙNG một biến thể
        sku: sku,                              // đúng biến thể (Size + Màu)
        stock: { $gte: qty }                   // chỉ khi tồn kho đủ số lượng mua
      } }
    },
```

```
    { $inc: { 'variants.$.stock': -qty } },    // trừ kho đúng phần tử mảng khớp
    { session }                                // dùng chung transaction (nếu có)
  );
  // modifiedCount = 0 nghĩa là hết hàng hoặc có người mua trước
  return result.modifiedCount === 1;
}

// Khi hủy đơn: cộng trả kho bằng phép cộng nguyên tử
async function releaseStock(productId, sku, qty, session) {
  await Product.updateOne(
    { _id: productId, 'variants.sku': sku },   // tìm đúng biến thể
    { $inc: { 'variants.$.stock': qty } },     // cộng trả số lượng
    { session }
  );
}
```

Ghi chú: giao dịch đa tài liệu cần bộ bản sao (replica set); báo cáo nêu Atlas cung cấp sẵn. Phương án dự phòng là hoàn kho thủ công các dòng đã trừ khi có dòng thất bại.

6. Kế hoạch kiểm thử (Dev 4 chủ trì)

Nhóm	Kịch bản	Kết quả mong đợi	Tuần
E2E	Khách mới → lọc → mua size cụ thể → đặt hàng → Admin xác nhận → xem lịch sử	Tồn kho giảm đúng; trạng thái đồng bộ hai phía; giá đơn = giá lúc mua	7
RBAC	Xóa sản phẩm bằng Customer; bằng request không cookie	403; 401; dữ liệu không đổi	4
IDOR	Customer A xem/hủy đơn của B bằng cách đổi mã đơn	Bị từ chối (403 hoặc 404)	7
XSS	Nhập thẻ script vào form địa chỉ/đánh giá	Bị loại ở Backend và không thực thi khi EJS hiển thị	7
Đồng thời kho	Biến thể còn 1, gửi nhiều request đặt hàng cùng lúc	Đúng 1 đơn thành công; tồn cuối = 0	7
Bộ lọc	Lọc M + Đỏ khi chỉ có M-Xanh và S-Đỏ	Sản phẩm không xuất hiện	4
CSRF	POST đặt hàng/hủy đơn từ trang ngoài, thiếu mã CSRF	403; đơn không tạo, trạng thái không đổi	7
Hiệu năng	Lighthouse Mobile trên bản deploy	Chỉ tiêu > 90; ghi số đo thực tế	7–8

7. Cân bằng tải và minh chứng đóng góp

Chỉ số	Dev 1	Dev 2	Dev 3	Dev 4
Số đầu việc (8 tuần × 3)	24	24	24	24
Tỷ lệ khối lượng	25%	25%	25%	25%
Phase 1 / 2 / 3 / 4	6 / 6 / 6 / 6	6 / 6 / 6 / 6	6 / 6 / 6 / 6	6 / 6 / 6 / 6
Thư mục chính	config, middlewares, auth	models, services	public, layouts, partials	pages, admin, tests, docs
Mục báo cáo tự viết	Bảo mật, Auth, Deploy app	CSDL, Nghiệp vụ, Deploy DB	Giao diện, Hiệu năng	Yêu cầu, Kiểm thử, Tổng hợp

- **Lưu ý trung thực:** chia đều theo số đầu việc, nhưng độ khó khác nhau (Dev 1, Dev 2 nặng logic; Dev 3, Dev 4 nặng giao diện/kiểm thử). Nhóm nên đối chiếu thêm số commit và PR mỗi tuần.
- Dev 1 và Dev 2 chia nhau việc đơn hàng (Dev 1: máy trạng thái, phân quyền; Dev 2: checkout, kho) để không ai quá tải ở Phase 3.
- Cuối mỗi Phase, xuất thống kê Git (`git shortlog -sn`) đưa vào bảng đóng góp để minh bạch.

8. Rủi ro và cách giảm thiểu

Rủi ro	Ảnh hưởng	Giảm thiểu
Chậm hợp đồng API giữa BE và FE	Dev 3, Dev 4 bị chờ	Chốt endpoint thứ Hai hằng tuần; dùng dữ liệu seed/giả lập để làm trước
Xung đột Git ở layout/partial dùng chung	Mất thời gian merge	Dev 3 sở hữu layout; Dev 4 chỉ thêm view và xin PR cho partial
Bán vượt kho	Sai nghiệp vụ nghiêm trọng	Trừ kho nguyên tử + test đồng thời ở Tuần 7
Lighthouse không đạt 90	Không đạt chỉ tiêu	Đo từ Tuần 4 (không đợi Tuần 7); tối ưu ảnh và JS từ sớm
Cookie Secure lỗi sau proxy	Không đăng nhập được khi deploy	Bật trust proxy; thử trên môi trường thật từ Tuần 7
Dữ liệu hành chính lỗi thời	Sai địa chỉ giao hàng	Xác nhận nguồn với giảng viên ở Tuần 1–2
Gói miễn phí hạ tầng thay đổi	Deploy không chạy	Đọc tài liệu chính thức trước Tuần 8; chuẩn bị phương án dự phòng

Tài liệu này là kế hoạch đề xuất. Các nội dung đánh dấu "cần xác nhận" chưa được kiểm chứng và nhóm nên hỏi giảng viên hoặc tra tài liệu chính thức trước khi áp dụng.